Netzwerkforensik

Dr. Stefan Hahndel

Technische Hochschule Ingolstadt
Fakultät für Elektrotechnik und Informatik

Gliederung der Teile 1-

1 Netzwerkforensik

Teil I

Erster Teil

Netzwerkgestützte Beweise sammeln

Definition

Die Netzwerkforensik versucht, Incidents anhand des Datenverkehrs zwischen Computern aufzuklären. Dies erfolgt entweder live unter Einsatz sogenannter IDS-Systemen oder post mortem anhand aufgezeichneter Netzwerkdaten.

Probleme in der Praxis

- Gängige IDS liefern oft zu viele Fehlalarme
- immer höhere Bandbreiten
- verschlüsselter Datenverkehr
- Echtzeitfilterung oder -aufzeichnung relevanter Daten

Macht Netzwerkforensik hier überhaupt noch Sinn ?

Technische Hochschule Ingolstadt
Fakultät für Elektrotechnik und Informatik

Verschiedene Abstraktionsebenen

Viele denken bei Netzwerkforensik zunächst an Tools wie tcpdump oder Wireshark (früheres Etherreal)

- Vollständige Aufzeichnung der Daten (Full Content Data)
  - Verkehr einzelner Clients/Rechner
  - Vollständiger Verkeht auf zentralem Knoten (z.B. zentraler Switch)
  - erfordert massenweise Speicherplatz
  - nur wenige Organisationen haben genug Ressourcen
- Sitzungsdaten (Session Data)
- Alarmierungsdaten (Alert Data)
- Statistische Daten

Full Content Data

```
0000  00 19 e0 97 f5 d4 00 11  09 b5 64 6f 08 00 45 00   ........ ..do..E.
0010  02 df c8 6f 40 00 40 06  5a ab c0 a8 01 1a c2 0f   ...o@.@. Z.......
0020  91 2c e0 8f 00 50 3e b1  a5 6d 8e 07 a7 29 80 18   .,...P>. .m...)..
0030  00 3f 20 54 00 00 01 01  08 0a 01 63 6a 9e 18 26   .? T.... ...cj..&
0040  3e cc 47 45 54 20 2f 64  61 62 69 70 2f 44 45 2f   >.GET /d abip/DE/
0050  64 65 2f 74 6f 6f 6c 73  2f 70 75 73 68 71 75 6f   de/tools /pushquo
0060  74 65 73 2f 70 75 73 68  53 65 72 76 69 63 65 2f   tes/push Service/
0070  6d 61 72 6b 65 74 6f 76  65 72 76 69 65 77 2e 6a   marketov erview.j
0080  73 70 3f 6c 61 73 74 74  69 6d 65 3d 31 31 38 37   sp?lastt ime=1187
0090  36 31 38 36 36 33 30 30  30 20 48 54 54 50 2f 31   61866300 0 HTTP/1
00a0  2e 31 0d 0a 48 6f 73 74  3a 20 77 77 77 2e 64 61   .1..Host : www.da
00b0  62 2d 62 61 6e 6b 2e 63  6f 6d 0d 0a 55 73 65 72   b-bank.c om..User
00c0  2d 41 67 65 6e 74 3a 20  4d 6f 7a 69 6c 6c 61 2f   -Agent:  Mozilla/
00d0  35 2e 30 20 28 58 31 31  3b 20 55 3b 20 4c 69 6e   5.0 (X11 ; U; Lin
00e0  75 78 20 69 36 38 36 20  28 78 38 36 5f 36 34 29   ux i686  (x86_64)
00f0  3b 20 64 65 2d 41 54 3b  20 72 76 3a 31 2e 38 2e   ; de-AT;  rv:1.8.
0100  31 2e 32 29 20 47 65 63  6b 6f 2f 32 30 30 37 30   1.2) Gec ko/20070
0110  32 32 31 20 53 65 61 4d  6f 6e 6b 65 79 2f 31 2e   221 SeaM onkey/1.
0120  31 2e 31 0d 0a 41 63 63  65 70 74 3a 20 74 65 78   1.1..Acc ept: tex
0130  74 2f 78 6d 6c 2c 61 70  70 6c 69 63 61 74 69 6f   t/xml,ap plicatio
0140  6e 2f 78 6d 6c 2c 61 70  70 6c 69 63 61 74 69 6f   n/xml,ap plicatio
0150  6e 2f 78 68 74 6d 6c 2b  78 6d 6c 2c 74 65 78 74   n/xhtml+ xml,text
0160  2f 68 74 6d 6c 3b 71 3d  30 2e 39 2c 74 65 78 74   /html;q= 0.9,text
0170  2f 70 6c 61 69 6e 3b 71  3d 30 2e 38 2c 69 6d 61   /plain;q =0.8,ima
0180  67 65 2f 70 6e 67 2c 2a  2f 2a 3b 71 3d 30 2e 35   ge/png,* /*;q=0.5
0190  0d 0a 41 63 63 65 70 74  2d 4c 61 6e 67 75 61 67   ..Accept -Languag
```

Full Content Data

Vorteile

- Vollständige Analyse bei unverschlüsseltem Verkehr möglich
- Experte kann damit Kommunikation exakt nachvollziehen
- z.B. Sprachverbindung bei VoIP (falls unverschlüsselt)
- Mit etwas Glück unverschlüsselte Passwörter
- Grösstmögliche Flexibilität bei Auswertung

Nachteile

- Enormer Speicherplatzbedarf
- Besonders arbeitsintensiv
- Man muss genau wissen, nach was man sucht

Sitzungsdaten (Session Data)

Definition

Zusammenfassung einer Kommunikationseinheit (Session), z.B. TCP-Verbindung oder UDP-Datenstrom.

- Quelle/Ziel (IP, Port)
- Protokoll (z.B. TCP, UDP, ICMP)
- Zeitstempel (Start/Ende)
- Datenmenge (Bytes, Pakete)

Beispielhafte Tools

Argus, NetFlow, Zeek (ehemals Bro)

Sitzungsdaten - Vgl. Telekomskandal

Nr.	Time	Source	Dest	Prot	
2033	51.3388	192.168.1.26	88.221.4.166	TCP	44242 > https [ACK] ...
2034	51.3391	88.221.4.166	192.168.1.26	TLSv1	Certificate
2035	51.3391	192.168.1.26	88.221.4.166	TCP	44242 > https [ACK] ...
2036	51.3434	192.168.1.26	88.221.4.166	TLSv1	Client Key Exchange, ...
2037	51.3932	88.221.4.166	192.168.1.26	TLSv1	Change Cipher Spec, ...
2038	51.3939	192.168.1.26	88.221.4.166	TLSv1	Application Data
2039	51.4497	88.221.4.166	192.168.1.26	TCP	[TCP segment of a ...
2040	51.4516	88.221.4.166	192.168.1.26	TCP	[TCP segment of a ...
2041	51.4516	192.168.1.26	88.221.4.166	TCP	44242 > https [ACK] ...
2042	51.4518	88.221.4.166	192.168.1.26	TLSv1	Application Data
2043	51.4700	192.168.1.26	88.221.4.166	TLSv1	Application Data
2044	51.5278	88.221.4.166	192.168.1.26	TCP	[TCP segment of a ...
2045	51.5297	88.221.4.166	192.168.1.26	TCP	[TCP segment of a ...
2046	51.5298	192.168.1.26	88.221.4.166	TCP	44242 > https [ACK] ...
2047	51.5317	88.221.4.166	192.168.1.26	TCP	[TCP segment of a ...
2048	51.5337	88.221.4.166	192.168.1.26	TCP	[TCP segment of a ...

Sitzungsdaten

Vorteile

- Datenvolumen (Speicherkapazität, Geschwindigkeit!)
- Schnelle Antwort auf folgende Fragen:
  - Mit wem findet wie oft Kommunikation statt?
  - Welche Art von Kommunikation? (z.B. VoIP, ftp, html?)
  - Welche Datenmengen werden dabei überragen?
  - Hinweise auf Kommunikationszweck, z.B. Wurm, Botnet etc.
- Fazit: Wichtige Hinweise auch bei verschlüsselter Kommunkation!

Nachteile

- Genauigkeit aufgrund unvollständiger Information

Alarmierungsdaten

Was versteht man unter Alarmierungsdaten?

Unter Alarmierungsdaten versteht man für die Untersuchung relevante „Datenschnipsel“ auf die gezielt Filterkriterien angewendet werden können.

Beispiele:

- Filterung nach Loginfeldern, um an wichtige Passwörter zu gelangen
- Filterung nach bestimmten fallabhängigen Schlüsselwörtern (vgl. Echelonsystem), z.B. Anschlag, Ernte, Bahnhof etc.
- Nach Verkehrsart filtern: z.B. nur Email, nur gnutella etc.
- Nach Ziel filtern: Zugriff auf www.illegal-content.de

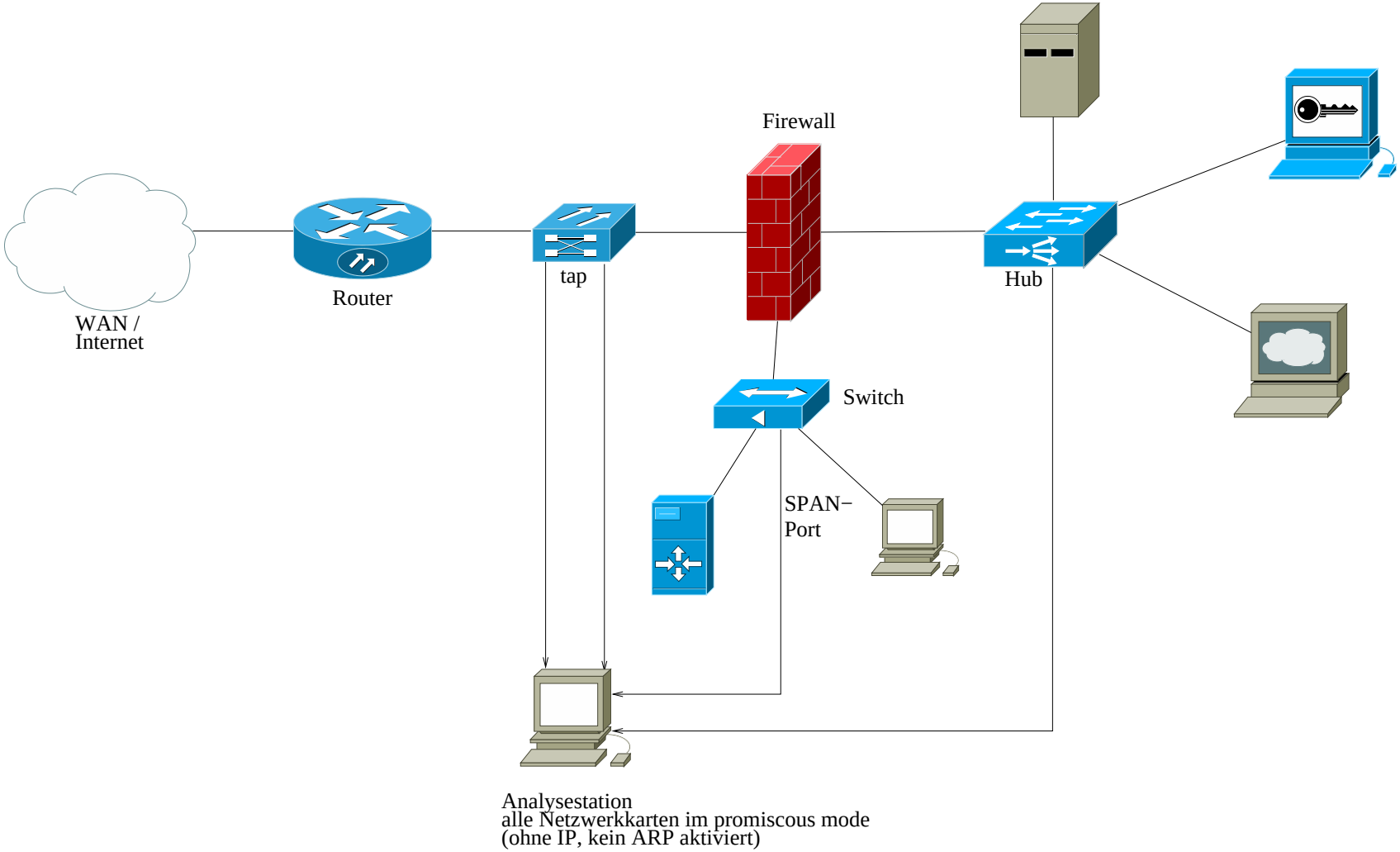
Auswertung statistischer Daten

- Statistische Daten sind nicht die erste Wahl wenn es um (detailierte) Bewertung oder Beseitigung eines Incidents geht
- Statistische Daten sind
  - inhaltsneutral
  - immun gegenüber Verschlüsselung
- Statistische Daten liefern Informationen
  - über Verwendungshäufigkeit ungewöhnliche Ports und Protokolle aufzuspüren
  - über ungewöhnlich hohes Datenvolumen in Einzelbereichen
  - Abweichungen vom normalen Verhalten
- Statistische Daten liefern häufig erst die entscheidenen Hinweise in welchen Bereichen nach was gesucht werden muss

Aufzeichnung relevanter Daten

- Wir haben alle vier Arten netzwerkbasierter forensischer Daten besprochen
- Wie kommen wir in der Praxis an relevante Aufzeichnungen?
- Vor dem Analyseschritt müssen die Daten z.B. durch Nutzung einer der vier folgenden Möglichkeiten abgegriffen werden
  - Nutzung von Hubs (Nachteil: fullduplex wird zu halbduplex)
  - Dazwischenschalten von Taps (Test Access Ports, 4 Ports zum abgreifen von TX und RX)
  - „Inline Device“ (eine Art selbstgebauter TAPs, z.B. Rechner mit Betriebssystem, das Bridges realisieren kann, z.B. Linux-PC !)
  - Switch Span Ports - bei vielen kommerziellen Switches verfügbar

Beispielhafte Aufzeichnung des Netzwerkverkehrs



Software-Tools zur (Full-Content-)Aufzeichnung und Analyse

- Tcpdump (http://www.tcpdump.org) ist das Standardtool, um Netzpackete aufzuzeichnen
- TCPdump ist auf nahezu allen Unix- und Linuxsystemen verfügbar und nutzt die Bibliothek libpcap
- Das Datenformat der libpcap ist der De-Facto-Standard zur Aufzeichnung von Netzwerk-Paketen
- Gute Suchtools:
  - `ngrep` (http://ngrep.sourceforge.net/)
  - `flowgrep` Gutes Tool von Nazario zur Suche regulärer Ausdrücke in Streams (http://www.monkey.org/ jose/software/flowgrep)
  - Gute Sammlung von Tools für Netzwerkmonitoring ist dsniff (http://monkey.org/ dugsong/dsniff/)

Technische Hochschule Ingolstadt
Fakultät für Elektrotechnik und Informatik

Netzwerkanalysetool „Wireshark“

File Edit View Go Capture Analyze Statistics Telephony Tools Help

Filter: Expression... Clear Apply

No.	Time	Source	Destination	Protocol	Info
504	158.743407	Devolo_1b:9f:14	Devolo_1b:95:af	0x88e1	Ethernet II
505	158.968822	192.168.1.26	173.194.35.166	HTTP	GET /__utm.gif?utmwv=5.3.3&utms=111&utmn=167214355&utmhn=sourceforge.net&utmt=event&utme=5(Ca
506	159.027201	173.194.35.166	192.168.1.26	HTTP	HTTP/1.1 200 OK (GIF89a)
507	159.027220	192.168.1.26	173.194.35.166	TCP	38397 > http [ACK] Seq=33473 Ack=12001 Win=501 Len=0 TSV=158820145 TSER=1013856151
508	159.983912	Devolo_1b:9f:14	Devolo_1b:95:af	0x88e1	Ethernet II
509	161.224564	Devolo_1b:9f:14	Devolo_1b:95:af	0x88e1	Ethernet II
510	162.465018	Devolo_1b:9f:14	Devolo_1b:95:af	0x88e1	Ethernet II
511	163.705325	Devolo_1b:9f:14	Devolo_1b:95:af	0x88e1	Ethernet II
512	163.987910	192.168.1.26	173.194.35.166	HTTP	GET /__utm.gif?utmwv=5.3.3&utms=112&utmn=1243935988&utmhn=sourceforge.net&utmt=event&utme=5(Ca
513	164.026408	Netgear_57:cc:1a	AsrockIn_5f:25:77	ARP	Who has 192.168.1.26? Tell 192.168.1.1
514	164.026464	AsrockIn_5f:25:77	Netgear_57:cc:1a	ARP	192.168.1.26 is at 00:25:22:5f:25:77
515	164.026747	192.168.1.1	192.168.1.26	NBNS	Name query NBSTAT *<00><00><00><00><00><00><00><00><00><00><00><00><00><00><00><00>
516	164.027038	192.168.1.26	192.168.1.1	NBNS	Name query response NBSTAT
517	164.047171	173.194.35.166	192.168.1.26	HTTP	HTTP/1.1 200 OK (GIF89a)

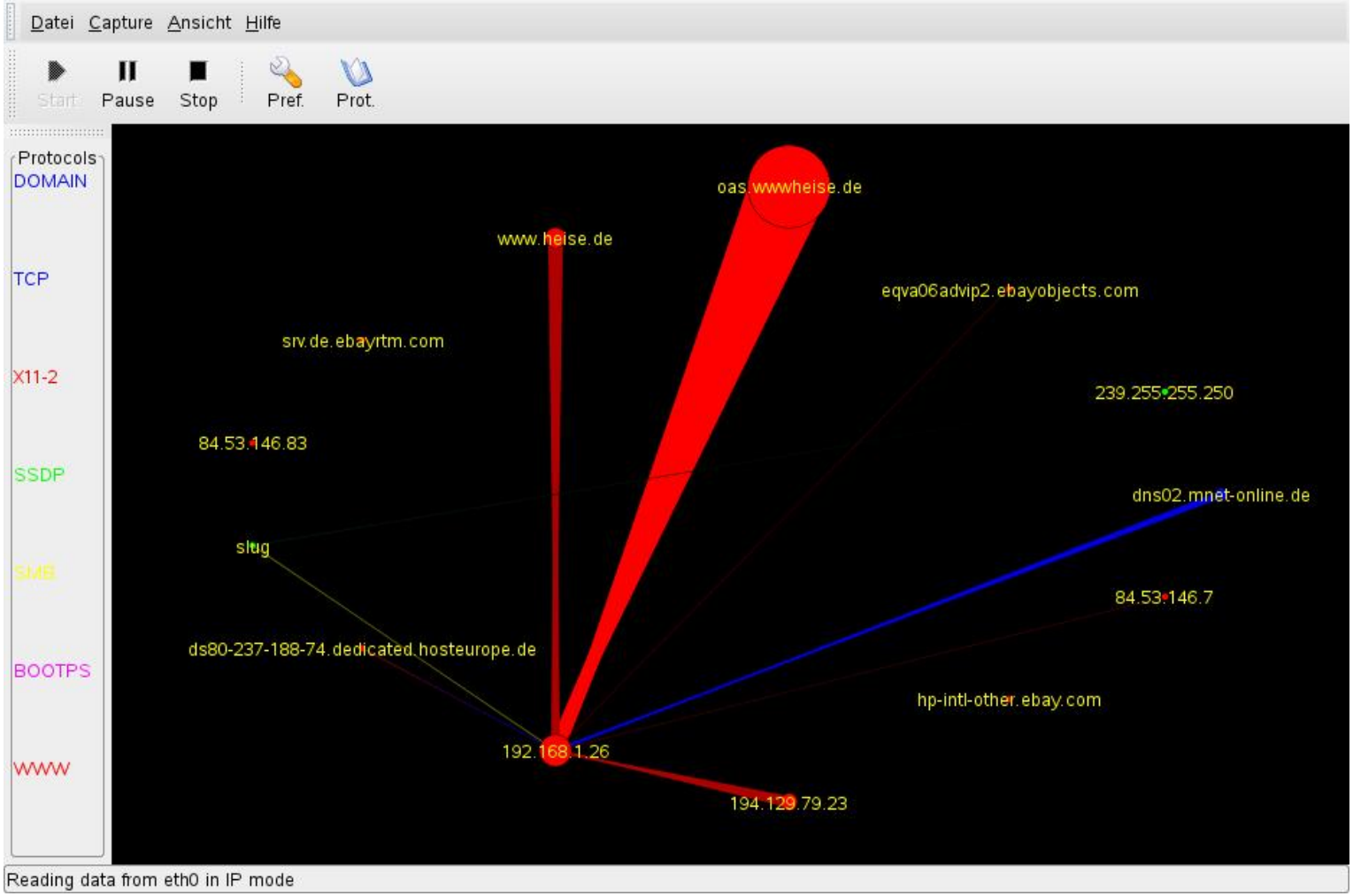
```
Frame 439: 444 bytes on wire (3552 bits), 444 bytes captured (3552 bits)
Ethernet II, Src: Goodman_30:2b:62 (00:11:41:30:2b:62), Dst: IPv4mcast_7f:ff:fa (01:00:5e:7f:ff:fa)
Internet Protocol, Src: 192.168.1.7 (192.168.1.7), Dst: 239.255.255.250 (239.255.255.250)
User Datagram Protocol, Src Port: ssdp (1900), Dst Port: ssdp (1900)
Hypertext Transfer Protocol
```

```
0020  ff fa 07 6c 07 6c 01 9a  21 b7 4e 4f 54 49 46 59   ...l.l.. !.NOTIFY
0030  20 2a 20 48 54 54 50 2f  31 2e 31 0d 0a 48 4f 53    * HTTP/ 1.1..HOS
0040  54 3a 20 32 33 39 2e 32  35 35 2e 32 35 35 2e 32   T: 239.2 55.255.2
0050  35 30 3a 31 39 30 30 0d  0a 43 41 43 48 45 2d 43   50:1900. .CACHE-C
0060  4f 4e 54 52 4f 4c 3a 20  6d 61 78 2d 61 67 65 3d   ONTROL:  max-age=
0070  31 38 31 30 0d 0a 4c 4f  43 41 54 49 4f 4e 3a 20   1810..LO CATION:
0080  68 74 74 70 3a 2f 2f 31  39 32 2e 31 36 38 2e 31   http://1 92.168.1
0090  2e 37 3a 39 30 30 31 2f  54 4d 53 44 65 76 69 63   .7:9001/ TMSDevic
00a0  65 44 65 73 63 72 69 70  74 69 6f 6e 2e 78 6d 6c   eDescrip tion.xml
00b0  0d 0a 4e 54 3a 20 75 72  6e 3a 6d 69 63 72 6f 73   ..NT: ur n:micros
00c0  6f 66 74 2e 63 6f 6d 3a  73 65 72 76 69 63 65 3a   oft.com: service:
00d0  58 5f 4d 53 5f 4d 65 64  69 61 52 65 63 65 69 76   X_MS_Med iaReceiv
00e0  65 72 52 65 67 69 73 74  72 61 72 3a 31 0d 0a 4e   erRegist rar:1..N
00f0  54 53 3a 20 73 73 64 70  3a 61 6c 69 76 65 0d 0a   TS: ssdp :alive..
0100  53 45 52 56 45 52 3a 20  4c 69 6e 75 78 2f 32 2e   SERVER:  Linux/2.
0110  78 2e 78 2c 20 55 50 6e  50 2f 31 2e 30 2c 20 70   x.x, UPn P/1.0, p
0120  76 43 6f 6e 6e 65 63 74  20 55 50 6e 50 20 53 44   vConnect  UPnP SD
0130  4b 2f 31 2e 30 2c 20 54  77 6f 6e 6b 79 4d 65 64   K/1.0, T wonkyMed
0140  69 61 20 55 50 6e 50 20  53 44 4b 2f 31 2e 31 0d   ia UPnP  SDK/1.1.
0150  0a 55 53 4e 3a 20 75 75  69 64 3a 35 35 30 37 36   .USN: uu id:55076
0160  66 36 65 2d 36 62 37 39  2d 34 64 36 35 2d 36 34   f6e-6b79 -4d65-64
0170  64 34 2d 30 30 31 31 34  31 33 30 32 62 36 32 3a   d4-00114 1302b62:
0180  3a 75 72 6e 3a 6d 69 63  72 6f 73 6f 66 74 2e 63   :urn:mic rosoft.c
0190  6f 6d 3a 73 65 72 76 69  63 65 3a 58 5f 4d 53 5f   om:servi ce:X_MS_
01a0  4d 65 64 69 61 52 65 63  65 69 76 65 72 52 65 67   MediaRec eiverReg
01b0  69 73 74 72 61 72 3a 31  0d 0a 0d 0a               istrar:1 ....
```

File: "/tmp/wiresharkXXXXjzSXYd" 99 KB 0... Packets: 566 Displayed: 566 Marked: 0 Dropped: 0 Profile: Default

Technische Hochschule Ingolstadt
Fakultät für Elektrotechnik und Informatik

Netzwerkanalysetool „Etherape“



Session Data Tools

- Argus von Carter Bullard (http://www.qosient.com/argus/)
  - seit 1995, wird aber stets weiterentwickelt
  - Batch or Live mode möglich
  - Kann im Live mode Session records im Speicher halten
  - Vermeidet dadurch Diskzugriff
- Tcptrace (http://www.tcptrace.org)
  - Für Batchmode-Analysen
  - Für Analysen von Tcpdump output auf Session Level
- Tcpflow (http://www.circlemud.org/)
  - Arbeitet mit Full Content Daten
  - Kann aber einzelne individuelle Sitzungen isolieren
  - (Funktion „Follow TCP Stream“ möglich), wird aber auch von Wireshark angeboten

Alert Data Tools

- Das bekannteste Tool ist das IDS (Intrusion Detection System) Snort (www.snort.org)
  - Snort ist weit verbreitet, gut verstanden und akzeptiert
  - Jeder Aspekt von Netzwerkpaketen kann über entsprechende Signaturen erfasst werden
  - Selbstdefinierte Regeln erlauben auch sehr komplexe Analysen
- Andere Alternativen sind z.B. u.a.
  - Shoki (http://shoki.sourceforge.net)
  - Bro (http://www-bro-ids.org/)
- Solche und ähnliche Tools bieten ihre Daten meist komfortabel über eine Webschnittstelle an
- Entscheidener Nachteil: Meist langsame Darstellung der Vergangenheit, Reloads notwendig
- Empfehlenswertes Tool auf Basis von `TCL/TK`: Sguil

Alert Data Tool Sguil (www.sguil.net)

SGUIL-0.7.0-ALPHA - Connected To 192.168.8.8

File Query Reports Sound: Off ServerName: 192.168.8.8 UserName: bamm UserID: 2 2007-03-20 21:13:19 GMT

RealTime Events | Escalated Events

ST	CNT	Sensor	Alert ID	Date/Time	Src IP	SPort	Dst IP	DPort	Pr	Event Message
RT	1	gateway	2.6692	2007-03-20 19:45:42	86.85.219.170		209.120.188.193		1	ICMP PING NMAP
RT	1	gateway	2.6730	2007-03-20 20:00:34	83.69.111.67		209.120.188.193		1	BLEEDING-EDGE WORM Allaple ICMP Sweep Ping Inbound
RT	1	gateway	2.6769	2007-03-20 20:18:02	217.113.225.107		209.120.188.193		1	BLEEDING-EDGE WORM Allaple ICMP Sweep Ping Inbound
RT	1	gateway	2.6874	2007-03-20 20:50:05	201.8.143.68		209.120.188.193		1	BLEEDING-EDGE WORM Allaple ICMP Sweep Ping Inbound
RT	1	gateway	2.6907	2007-03-20 21:12:20	194.65.57.37		209.120.188.193		1	BLEEDING-EDGE WORM Allaple ICMP Sweep Ping Inbound

ST	CNT	Sensor	Alert ID	Date/Time	Src IP	SPort	Dst IP	DPort	Pr	Event Message
RT	1	gateway	2.6298	2007-03-19 08:03:51	87.240.48.122	1173	209.120.188.193	1434	17	MS-SQL version overflow attempt
RT	1	gateway	2.6380	2007-03-19 18:37:24	220.178.43.82	3064	209.120.188.193	1434	17	MS-SQL version overflow attempt
RT	1	gateway	2.6387	2007-03-19 19:16:20	202.101.62.218	1030	209.120.188.193	1434	17	MS-SQL version overflow attempt
RT	1	gateway	2.6541	2007-03-20 09:14:49	82.254.65.178	1984	209.120.188.193	80	6	http_inspect: OVERSIZE REQUEST-URI DIRECTORY

ST	CNT	Sensor	Alert ID	Date/Time	Src IP	SPort	Dst IP	DPort	Pr	Event Message
RT	1	gateway	4.1	2007-03-01 00:19:49	162.18.202.71	39842	209.120.188.193	80	6	PADS New Asset - www Apache 2.0.52 (CentOS)
RT	1	gateway	4.2	2007-03-01 00:20:05	24.85.138.40	1269	209.120.188.193	7734	6	PADS New Asset - unknown unknown
RT	1	gateway	4.3	2007-03-01 02:49:52	202.188.160.53	45398	209.120.188.193	22	6	PADS New Asset - ssh OpenSSH 3.9p1 (Protocol 1.99)
RT	1	gateway	4.4	2007-03-01 05:35:33	211.147.250.20	6000	209.120.188.193	3128	6	PADS New Asset - www squid/2.5.STABLE6
RT	1	gateway	4.5	2007-03-03 03:40:46	82.96.96.3	38419	209.120.188.193	23	6	PADS New Asset - ssh OpenSSH 3.9p1 (Protocol 1.99)
RT	1	gateway	4.6	2007-03-08 15:13:20	162.18.202.88	40942	209.120.188.193	44	6	PADS New Asset - ssh OpenSSH 4.3 (Protocol 2.0)

IP Resolution | Agent Status | Snort Statistics | System Msgs | User Msgs

Reverse DNS

Src IP: 82.96.96.3
Src Name: please.read.http.proxyscan.freenode.net
Dst IP: 209.120.188.193
Dst Name: 193-188-120-209.static.mesanetworks.net

Whois Query: None Src IP Dst IP

```
% This is the RIPE Whois query server #2.
% The objects are in RPSL format.
%
% Note: the default output of the RIPE Whois server
% is changed. Your tools may need to be adjusted. See
% http://www.ripe.net/db/news/abuse-proposal-20050331.html
% for more details.
%
% Rights restricted by copyright.
% See http://www.ripe.net/db/copyright.html
```

Display Detected Banner

```
01 01 08 0A EC 60 F8 C0  3A 6E 7B 0A 01 01 08 0A
EC 60 F8 C2 3A 6E 7B 0A  01 01 08 0A EC 60 F8 E3
3A 6E 7B 0A 53 53 48 2D  31 2E 39 39 2D 4F 70 65
6E 53 53 48 5F 33 2E 39  70 31 0A
```

```
.....`.. :n{.....
. ..:n{. .....`..
:n{.SSH- 1.99-Ope
nSSH_3.9 p1.
```

Technische Hochschule Ingolstadt
Fakultät für Elektrotechnik und Informatik

Tools für statistische Daten

- `tcpdstat` (http://staff.washington.edu/dittrich/talks/core02/tools/tools.html)
- `Trafshow` (http://soft.risp.ru/trafshow/index_en.shtml) leistet gute Dienste beim finden der „Top Talker“
- Tcpstat und NTop dienen eher Performancemessungen und haben für forensische Analysen einen eher kleineren Stellenwert

Forensicher Wert verschiedener Quellen I

- Direkt abgreifen „vom Draht“: Zahlreiche Möglichkeiten, Taps oder Schnittstellen an Netzwerkgeräten
- Drahtlos: WLAN, Bluetooth, Infrarot etc., forensischer Wert: agieren wie Hubs, viele Infos IMMER unverschlüsselt, z.B. MACS
- Switches: Content Adressable Memory, Span Port $\longrightarrow$ Sniffer
- Router: Routing Tables, Logs (z.B. Denied traffic), volatile memory etc.
- DHCP-Server: Zuordnung IP-Adressen pro Zeiteinheit
- DNS-Server: Logging von DNS-Abfragen
- Authentication Server: Logs von (nicht) erfolgreichen login-Versuchen

Forensicher Wert verschiedener Quellen II

- Network Intrusion Detection: Offensichtlich
- Firewalls: Protokollierung zahlreicher Ereignisse, z.B. verworfener Pakete etc.
- Web-Proxies: Protokollierung von Zugriffen auf Webseitena $\longrightarrow$ Goldmine!
- Application Server: Zahlreiche verschiedene Arten / Möglichkeiten
  - Datenbankserver, Webserver, Emailserver
  - Chatserver, VoIP oder Voicemail, Wikis, Foren etc.
  - Zuviele Möglichkeiten, hier alle einzeln zu behandeln
- Zentrale Logserver

Berkeley Packet Filter Language

- Unterstützt z.B. von der libpcap
- Erlaubt Aufstellung von Filterregeln auf Layer 2,3,4 Protokollen
- „Build-in Primitiva“ für alle wichtigen Protokollfelder
- .type gibt an, auf was die id verweist, z.B. host, net, port, portrange
- .dir spezifiziert Transportrichtung (von/zur ID), z.B. src,dst,addr1, ...
- .proto beschränkt auf bestimmte Protokollarten: ether,fddi,tr,wlan,ip, ip6,arp,rarp,decnet,tcp,udp

Zeek: Netzwerkforensik auf hohem Niveau

Was ist Zeek?

Zeek (früher *Bro*) ist ein leistungsfähiges Framework zur netzwerkbasierten Überwachung.

- Open-Source, entwickelt ursprünglich am LBNL (Lawrence Berkeley National Laboratory)
- Modular und skriptbar
- Nutzt Session-, Header- und Anwendungsdaten
- Fokus auf Ereignisse statt Pakete

Wie funktioniert Zeek?

- Analysiert Verkehr passiv im Hintergrund
- Erkennt Protokolle durch dynamische Analyse (kein Port-basiertes Matching!)
- Generiert strukturierte Logs:
  - `conn.log`: Übersicht über Verbindungen
  - `http.log`, `dns.log`, `ssl.log`, ...
- Reagiert auf Events über Skriptsystem

Beispiel:

Event bei auffälligem User-Agent in HTTP-Verkehr: Logging oder Alarm

Vorteile von Zeek

- Extrem anpassbar durch eigenes Skript-System
- Loggt viele Protokolle auch im verschlüsselten Kontext (z.B. TLS-Metadaten)
- Integration in SIEM-Systeme möglich
- Ideal für post-mortem Analysen großer Netzwerke
- Hohe Performance durch effiziente Verarbeitung

Zeek-Logs am Beispiel (http.log)

```
1521911720.123456 CXYZ123abcXYXYXY 192.168.1.10 50562
10.0.0.42 80 GET www.example.com /index.html
HTTP/1.1 200 OK Mozilla/5.0
```

- IPs, Ports, Pfad, Statuscode, User-Agent
- Ideal für Korrelation mit anderen Ereignissen

Zeek Einsatzszenarien

- Aufzeichnung und Analyse von Netzverkehr in Unternehmen
- Threat Hunting / Incident Response
- Erkennung von Low and Slow Angriffen
- Analyse von Advanced Persistent Threats (APT)
- Unterstützung von Compliance-Vorgaben (z.B. ISO 27001)

Zeek-Skript: Erkennung von .exe-Downloads

```
# Datei: detect_exe_download.zeek
# Aufruf über: zeek -r traffic.pcap detect_exe_download.zeek

event http_entity_data(c: connection, is_orig: bool,
                       len: count, data: string)
{
  if ( /.*\.exe$/.match(c$id$uri) ) {
    print fmt("EXE-Download erkannt: %s -> %s URI: %s",
              c$id$orig_h, c$id$resp_h, c$id$uri);
  }
}

event http_reply(c: connection, version: string, code: count,
         reason: string)
{
  if (c?$http && c$http?$mime_type) {
    if ( c$http$mime_type == "application/x-msdownload" ||
         c$http$mime_type == "application/octet-stream" ) {
      print fmt("Möglicher EXE-Download (%s): %s -> %s URI: %s",
                c$http$mime_type, c$id$orig_h, c$id$resp_h, c$id$uri);
    }
  }
}
```

Praktische Übung anhand pcap-File attack.pcap.gz

1. Which systems (i.e. IP addresses) are involved? (2pts)
2. What can you find out about the attacking host (e.g., where is it located)? (2pts)
3. How many TCP sessions are contained in the dump file? (2pt)
4. How long did it take to perform the attack? (2pts)
5. Which operating system was targeted by the attack? And which service? Which vulnerability? (6pts)
6. Can you sketch an overview of the general actions performed by the attacker? (6pts)
7. What specific vulnerability was attacked? (2pts)
8. What actions does the shellcode perform? Pls list the shellcode (8pts)
9. Do you think a Honeypot was used to pose as a vulnerable victim? Why? (6pts)
10. Was there malware involved? Whats the name of the malware (We are not looking for a detailed malware analysis for this challenge) (2pts)
11. Do you think this is a manual or an automated attack (2pts)?

Werkzeugtipps

- Wirereshark
- tcpdump
- Network Miner
- Rumint
- scapy
- capinfos
- nslookup
- whois
- strings
- Maxmind.com
- Google Maps
- PEiD
- TrID
- exeinfo
- P0f
- dig
- Nmap
- Traceroute
- Snort
- Tcpflow
- Tcpxtract
- Foremost
- Scalpel
- dionaea
- tshark
- libemu
- IDA-Pro
- Perl, Python ;-)

Viel Spaß!